

Developer Fix Checklist — BErozgar

BErozgar — Developer Fix Checklist

Generated: April 2026 | Version: V0.1.0 | Audit: Phase 7 FinalTotal Issues: 25 | Critical: 1 | High: 14 | Medium: 5 | Low: 3 | Info: 2

PRIORITY 0 — Do Today (Unblocks All Further Testing)

- [P0 | BEZ-001 | CRITICAL]**Add accessibility and test attributes to login form inputs**File:**
src/components/LoginForm.jsx (or wherever the login form is rendered)**Change:**Add
name="email" id="email" data-testid="email-input" to email field; add
name="password" id="password" data-testid="password-input" to password
field; add data-testid="login-submit" type="submit" to the submit button**Also add:**
<label htmlFor="email">Email</label> and
<label htmlFor="password">Password</label> for accessibility**Acceptance:**
Playwright script can locate [data-testid="email-input"] , type into it, and submit the
form; screen readers announce field labels**Effort:**S — 2hours**Why urgent:**Blocks 80%of QA
test suite AND is an accessibility violation
- [P0 | BEZ-008 | HIGH]**Add security headers to Nginx configuration**File:**
/etc/nginx/nginx.conf or /etc/nginx/conf.d/default.conf **Change:**Add inside
the server {} block:
add_header Strict-Transport-Security "max-age=31536000;
includeSub-
Acceptance: curl -I https://rgitrozgar.in returns all 6headers; Mozilla Observatory
add_header X-Frame-Options DENY always;
same origin. **Effort:**S — 2hours**Verify:** rigin" always;
https://observatory.mozilla.org/analyze/rgitrozgar.in after deployment
buv request will fail security policy default 315 set; script-src
set; style-src set; unsafe-inline; img-src set; data: https;;
- [P0 | BEZ-002 | HIGH]**Fix missing PrivateRoute guard on /admin/dashboard**File:**
src/router/index.jsx or src/App.jsx **Change:**Wrap
add header Permissions-Policy: "camera=(), microphone=(), geolocation=()"
<Route path="/admin/dashboard"> with <PrivateRoute requiredRole="admin">
,,,,,
components, and all routes under /admin/ and ensure each has the same guard; verify
/admin/users , /admin/jobs , /admin/settings , /admin/companies are all
protected**Acceptance:**Unauthenticated GET to /admin/dashboard returns 302redirect to
/login (not 404); same for all /admin/ sub-routes**Effort:**S — 1hour
*

PRIORITY 1 — Fix This Sprint (Before Launch)

- [P1 | BEZ-004 | HIGH]** Fix 404 page white background breaking dark theme **File:**
`src/pages/NotFound.js` or `src/components/ErrorBoundary.jsx` **Change:** Wrap component in global `<AppLayout>` or `<PageWrapper>`; remove any `className="bg-white"` or inline `style={{ backgroundColor: 'white' }}`; apply `className="bg-black"` or `var(--bg-primary)` to root container **Acceptance:** Navigate to `/register` — page renders with dark background; no white flash; consistent with `/home` and `/login` visual style **Effort:** S — 30 minutes
- [P1 | BEZ-005 | HIGH]** Fix mobile viewport overflow on landing page hero **File:**
`src/pages/Landing.jsx` or `src/components/Hero.js` **Change:** Replace fixed font size on hero heading (`"BUILDING CAMPUS"`) with:
`font-size: clamp(2rem, 5vw, 5rem);`; add
`word-wrap: break-word; overflow-wrap: break-word;` to hero heading; add
`overflow-x: hidden;` to hero section container; test CTA buttons stack correctly at 375px **Acceptance:** No horizontal scroll at 375px viewport; hero text wraps cleanly; CTA buttons are fully visible and tappable **Effort:** S — 1 hour
- [P1 | BEZ-006 | HIGH]** Standardize Navbar component across all routes **File:**
`src/components/Navbar.jsx` **Change:** Add `variant` prop with values `"minimal"` (for `/login` — no nav links, just logo) and `"full"` (for `/home` and authenticated routes — full nav with links); delete the numbered menu array (`0` , `0` , etc.) from the 404 page and replace with standard nav array; ensure auth state is reflected in navbar (show Dashboard link when `isAuthenticated === true`) **Acceptance:** All 4 tested routes show consistent navigation pattern; 404 page no longer shows numbered items; logged-in users see Dashboard link in navbar **Effort:** M — 1 day
- [P1 | BEZ-009 | HIGH]** Verify and harden JWT implementation **File:** Fastify auth plugin + `src/server/routes/auth.js` **Step 1 — Verify (manual, 1 hour):** Login with admin credentials → open DevTools → Application tab → check Cookies vs localStorage → decode token:
`JSON.parse(atob(token.split('.')[1]))`
 → verify `alg`, `exp`, `rol` claims **Step 2 — Fix if needed:** Migrate to httpOnly cookie:
`reply.setCookie('token', token, { httpOnly: true, secure: true, sameSite: 'strict' })`
 ; configure `@fastify/jwt` with `sign: { algorithm: 'HS256', expiresIn: '1h' }` and `verify: { algorithms: ['HS256'] }` **Acceptance:** Token in httpOnly cookie (NOT localStorage); `alg=HS256`; `exp` `leq 3600`; `rol` claim present; student token rejected by `/api/admin/users` with 403 **Effort:** M — 1 day
- [P1 | BEZ-010 | HIGH]** Test and fix XSS input validation **Files:** All form components + Fastify route handlers **Manual test:** Enter `<script>alert(1)</script>` and `"><img src=x onerror=alert(1)>` in all text inputs (login, signup, profile, job search, resale listing) **Fix:** Ensure React renders all user input via JSX (not `dangerouslySetInnerHTML`); add server-side sanitization using `sanitize-html` or `DOMPurify` for any rich text fields; CSP header (BEZ-008) provides defense-in-depth

Acceptance: XSS payloads render as literal text; no alert dialogs; no script execution; CSP header blocks inline scripts
Effort:M — 1day

- **[P1 | BEZ-011 | HIGH]**Verify SQL injection protection**Files:**All files containing
`prisma.$queryRaw` or `prisma.$executeRaw` **Audit:**Run
`grep -r "queryRaw\|executeRaw" src/server/` — any results must use tagged
template literals (`prisma.$queryRaw`SELECT * FROM users WHERE id = ${userId}``)
NOT string concatenation (`prisma.$queryRaw("SELECT * FROM users WHERE id = " + userId)`)**Manual test:**
Enter `' OR` and `;` DROP TABLE in login email field
Acceptance:No raw queries with string concatenation; login with SQL payload returns “Invalid credentials”;
SQLMap scan returns no vulnerabilities**Effort:**S — 4hours
- **[P1 | BEZ-012 | HIGH]**Implement session invalidation on logout**Files:**
`src/server/routes/auth.js` (logout handler) + frontend logout component**Backend**
option A (recommended):Implement Redis-based JWT blacklist — on logout, add token
`jti` claim to Redis with TTL matching token expiry; on every authenticated request, check
Redis blacklist**Backend option B (simpler):**Use short-lived tokens (15min) + refresh token
rotation — logout invalidates refresh token in DB**Frontend:**On logout, call
`document.cookie = 'token=; expires=Thu, 01 Jan 1970 00:00:00 UTC;`
`path' ;`
AND `localStorage.clear()` **Acceptance:**Old token rejected by GET after
logout (401); `localStorage` empty after logout; browser back button after logout cannot
access protected pages**Effort:**M — 1day
- **[P1 | BEZ-022 | HIGH]**Implement Vite route-level code splitting**File:** `vite.config.ts` +
`src/router/index.jsx` **vite.config.ts change:**
`build: {`
`rollupOptions: {`
Router change:Wrap all route components with `React.lazy()` :
`output: {`
`const Dashboard = React.lazy(() => import('./pages/Dashboard'));`
`const Home = React.lazy(() => import('./pages/Home'));`
`const Login = React.lazy(() => import('./pages/Login'));`
`const Logout = React.lazy(() => import('./pages/Logout'));`
`// wrap routes@radix-ui/react-router-dom`
Acceptance:Network tab shows multiple JS chunks on initial load; initial bundle < 200KB
gzipped; LCP < 2.5s on PageSpeed Insights**Effort:**M — 1day
- **[P1 | BEZ-023 | HIGH]**Deploy PgBouncer connection pooler**File:** `docker-compose.yml` +
`.env` **docker-compose.yml addition:**
`pgbouncer:`
`image: edohuru/pgbouncer:latest`
Update DATABASE_URLChange Prisma connection from
`environment:`
`postgres://...@postgres:5432/berozgar` to `postgres://...@postgres:5432/berozgar`
`postgres://...@pgbouncer:5432/berozgar?connection_limit=10` **Acceptance:**
`MAX_CLIENT_CONN. 1000`
Application handles 200 concurrent requests without connection timeout;
`pg_stat_activity` shows leq 25 active connections under load; zero “connection pool
exhausted” errors in logs**Effort:**M — 4hours

PRIORITY 2 — Fix Next Sprint

- **[P2 | BEZ-003 | MEDIUM]** Resolve three-way domain mismatch **Files:** robots.txt , sitemap.xml , nginx.conf , CORS configuration **Changes:** Update robots.txt Sitemap line to https://rgitrozgar.in/sitemap.xml ; update all 8 URLs in sitemap.xml to use rgitrozgar.in ; document the rkgit.ezexam.in relationship in architecture docs; audit CORS allowedOrigins to ensure rkgit.ezexam.in is not inadvertently allowed **Acceptance:** robots.txt and sitemap.xml reference only rgitrozgar.in ; no cross-origin requests to rkgit.ezexam.in in Network tab **Effort:** S — 2 hours
- **[P2 | BEZ-007 | MEDIUM]** Create unified Button component **File:** src/components/ui/Button.jsx (create if not exists) **Change:** Create <Button variant="primary|outline|ghost|danger"> component; primary = filled cyan #00D9FF with dark text; outline = transparent with cyan border; apply to all CTAs on Landing, Login, Home pages; delete all inline button styles **Acceptance:** All primary CTAs across all pages use identical visual style; no inline button styles remain **Effort:** S — 4 hours
- **[P2 | BEZ-013 | HIGH]** Implement IDOR protection on all object endpoints **Files:** All Fastify route handlers for /api/profile/:id , /api/applications/:id , /api/resale/:id **Change:** Add ownership check to every object-level endpoint:


```
const resource = await prisma.profile.findUnique({ where: { id: params.id } });
if (!resource) return reply.status(404).send({ error: 'Not Found' });
return resource.userId === request.user.id && request.user.role !== 'admin' ?
  reply.status(403).send({ error: 'Forbidden' }) :
  reply.status(200).send(resource);
```

Acceptance: Student A cannot access Student B's profile by incrementing the ID in the URL; if resource not found, return 404; if not owned, return 403 **Effort:** M — 1 day
- **[P2 | BEZ-014 | HIGH]** Fix email enumeration vulnerability **File:** src/server/routes/auth.js login handler **Change:** Return identical error message and identical response time for both “wrong password” and “email not found” cases:


```
// Always return this, regardless of whether email exists:
return reply.status(401).send({ error: 'Invalid credentials' });
// Add artificial delay if needed to normalize timing:
body.timing.asinValidEmail + anyPassword (200ms);
```

Acceptance: POST /api/auth/login with valid email + wrong password returns identical body and timing as invalid email + any password **Effort:** S — 2 hours
- **[P2 | BEZ-015 | MEDIUM]** Suppress Fastify error details in production **File:** src/server/app.js Fastify initialization **Change:**

```
fastify.setErrorHandler((error, request, reply) => {
  const { statusCode = 500, message } = error;
  if (process.env.NODE_ENV === 'production') {
    genericMessages[statusCode] ?
      reply.status(statusCode).send({ error: 'Not Found' }) :
      reply.status(500).send({ error: 'Internal Server Error' });
  } else {
    reply.status(statusCode).send({ error, message });
  }
});
```

Also set: NODE_ENV=production in Docker environment **Acceptance:** API errors return generic messages, no Fastify version, route structure, or stack traces in responses **Effort:** S — 2 hours
- **[P2 | BEZ-016 | MEDIUM]** Fix HTTP 405 for wrong-method requests on auth endpoints **File:** src/server/routes/auth.js Fastify route definitions for /api/auth/login **Change:** Add explicit GET handler returning 405:

```
fastify.get('/api/auth/login', async (request, reply) => {
  return reply.status(405).send({ error: 'Method Not Allowed' });
});
```

Acceptance: GET /api/auth/login returns 405 Method Not Allowed with Allow: GET header **Effort:** S — 1 hour
- **[P2 | BEZ-021 | HIGH]** Set up Cloudflare CDN **Infrastructure:** Cloudflare dashboard (free tier sufficient) **Steps:** Add rgitrozgar.in to Cloudflare; update DNS nameservers; enable “Cache Everything” page rule for /assets/* ; enable Brotli compression in Speed settings;

enable HTTP/2 (automatic on Cloudflare)**Nginx addition:**

```
add_header Cache-Control "public, max-age=31536000, immutable"; for
```

```
/assets location blockAcceptance:Response headers include CF-Ray ; /assets
```

files served from edge cache (CF-Cache-Status: HIT); LCP improvement of **20–40%** for users outside server region**Effort:**S — 2hours

- **[P2 | BEZ-024 | MEDIUM]**Investigate and fix /dashboard timeout anomaly**File:**

```
src/server/routes/dashboard.js + React Router config + Nginx configInvestigation:
```

Navigate to /dashboard and monitor: **(1)** Nginx access logs for the request; **(2)** Fastify logs for any processing; **(3)** React Router for redirect loops; **(4)** Check if Nginx

```
proxy_read_timeout is setLikely cause:Infinite redirect loop between /dashboard
```

→ /login → /dashboard when auth state is ambiguous**Fix:**Add explicit timeout and fallback in auth middleware; ensure redirect chain terminates**Acceptance:**

```
/dashboard responds within 2seconds (either redirect to /login or page load); no
```

timeout in browser**Effort:**M — 4hours

PRIORITY 3 — Backlog (Nice to Have)

- **[P3 | BEZ-017 | LOW]**Add /api/health endpoint**File:** src/server/routes/health.js
Change:

```
fastify.get('/api/health', async () => ({ status: 'ok', version: '0.1.0',  
timestamp: Date.now() })))Effort:S — 30minutes
```

- **[P3 | BEZ-018 | LOW]**Remove AUTH_PROTOCOL display from login page**File:**

```
src/pages/Login.jsx Change:Delete or comment out the
```

```
AUTH_PROTOCOL: HMAC_HMAC_SHA256 display elementEffort:S — 15minutes
```

- **[P3 | BEZ-019 | INFO]**Remove version string from public UI**File:**

```
src/components/Footer.jsx or src/pages/Landing.jsx Change:Move v0.1.0
```

version display to admin dashboard only; remove from public landing page**Effort:**S — 15 minutes

- **[P3 | BEZ-020 | INFO]**Change .env nginx response from 403to 404**File:**

```
/etc/nginx/nginx.conf Change:Add location ~ /\.env { return 404; } before  
the main location blockEffort:S — 15minutes
```

- **[P3 | BEZ-025 | LOW]**Add /contact page or redirect**File:** src/router/index.jsx **Change:**

Add /contact route with contact information for MCTRGIT placement cell, or redirect to appropriate page**Effort:**S — 1hour

Summary

Priority	Count	Total Estimated Effort
P0(Do Today)	3	~5hours
P1(This Sprint)	8	~8days
P2(Next Sprint)	8	~5days
P3(Backlog)	5	~2hours
Total	24	~14days

Critical Path:BEZ-001(2hours) → unlocks full QA suite → BEZ-009, BEZ-010, BEZ-011, BEZ-012can be verified → BEZ-008+ BEZ-002(3hours) → system is minimally secure → BEZ-022+ BEZ-023(2days) → system is minimally scalable → **GO for limited launch**

Minimum viable secure launch:P0complete + BEZ-004, BEZ-009, BEZ-010, BEZ-011, BEZ-012, BEZ-008, BEZ-022, BEZ-023complete = approximately **10**working days for **one**senior full-stack developer.

Checklist generated by Phase 7Final Verdict Assembler | BErozgar Audit April 2026

References

- [1] "Vite vs Webpack: 5 Tests, 1 Clear Winner [2026] - Tech Insider".
<https://tech-insider.org/vite-vs-webpack-2026/>